

CHT Platform — Combined Assessment Report

Community Health Technologies (CHT) Platform Tool

Report date: May 22, 2026

Prepared for: Internal stakeholders — compliance, engineering, and product leadership

Scope: Leadership summary, use cases, external dependencies, SOC 2 readiness, codebase quality, MVP vs enterprise-grade assessment

CHT Platform Leadership Summary

Product Status, Risk Posture, and Recommended Next Steps

The CHT platform is a **functioning production MVP**, not a prototype. Core healthcare education workflows are in place, including webinar registration, Zoom attendance tracking, post-event surveys, honorarium payment workflows, CME certificate delivery, HCP profiles, KOL pages, podcast content, and admin audit logging. The technical review confirms the platform is suitable for **controlled production use**, but **not yet enterprise-grade**.

The scores in this report are based on **enterprise standards**, not MVP standards. Under MVP standards, the platform is in a **strong position**. Under enterprise standards, gaps remain across ownership, testing, compliance evidence, disaster recovery, observability, and vendor management.

Current Readiness

Area	Current Status
Production MVP	Yes
Growth-stage platform	In progress
Enterprise-grade platform	Not yet
SOC 2 audit-ready	Not yet
Enterprise reliability	Not yet
Strong foundation to harden	Yes

Primary Product Risk: MediaHub Dependency

MediaHub remains the biggest structural product risk, but the issue should be framed precisely.

Podcasts are not the problem. They are already connected directly to the YouTube API and working well. That should be treated as the model.

The unresolved MediaHub risks are:

Area	Current State	Risk
Authentication	MediaHub GoTrue/Supabase — CHT users are MH auth users	Critical
End-user MediaHub exposure	OAuth redirect through MediaHub hostname	High
Conversation playlists	Still dependent on MediaHub API	High
KOL/content/catalog structure	Still tied to MediaHub workflows	High
Podcasts	Direct YouTube API integration and working well	Low

Approved auth strategy (June 2026): CHT owns the IdP — migrate to **Amazon Cognito** with required TOTP MFA. **KOL, HCP, and industry users must never authenticate through or access MediaHub.** MediaHub **decommissions GoTrue for all non-admin users** and stops receiving CHT auth users. **Only CHT admins** may access MediaHub UI. Server-to-server integration with MediaHub **continues via API key** (catalog, HCP sync) — not user auth. See [CHT-Auth-Decoupling-Next-Steps-Report.md](./CHT-Auth-Decoupling-Next-Steps-Report.md).

Authentication on shared MediaHub GoTrue is the **highest-risk dependency** until Cognito cutover. CHT cannot fully control access governance, MFA, or SOC 2 IdP evidence while end users remain GoTrue auth users on MediaHub.

Enterprise Score Context

The technical review gives CHT an overall SOC 2 readiness score of approximately **58/100**. This does not mean the product does not work. It means the product is **not yet audit-ready** under enterprise standards. Technical controls are stronger at **72/100**, but policies and procedures are at **45/100**, and vendor management is at **40/100**.

Readiness Category	Current Estimate
MVP readiness	85–90%
Growth-stage readiness	~60%
Enterprise readiness	~40%
SOC 2 readiness	~58/100

Projected Score After Decoupling

If CHT migrates authentication to **Cognito (CHT-owned IdP)**, MediaHub **decommissions GoTrue for end users**, removes conversation playlist dependency from live MediaHub API calls, and moves KOL/content/catalog ownership into CHT, the readiness profile improves materially.

Readiness Category	Current Estimate	Projected After Decoupling
MVP readiness	85–90%	92–96%
Growth-stage readiness	~60%	76–82%
Enterprise readiness	~40%	62–67%
SOC 2 readiness	~58/100	72–76/100

This would move CHT from a production MVP with dependency risk to a **strong growth-stage platform** with a credible path to enterprise readiness. It would not complete the enterprise journey, but it would remove one of the largest structural blockers.

Highest-Priority Gaps

1. Migrate authentication from MediaHub GoTrue to **Amazon Cognito (CHT-owned IdP + MFA)**; MediaHub decommissions GoTrue for non-admin users.
2. End users (KOL/HCP/industry) must not see or access MediaHub — CHT domain and APIs only.
3. Conversation playlists still depend on the MediaHub API.
4. KOL/content/catalog ownership is still too fragmented.
5. Automated test coverage is too low, with roughly **8% backend module coverage** and **5% frontend page coverage**.
6. SOC 2 evidence is incomplete.
7. RDS is currently single-AZ, creating availability risk.
8. Observability is incomplete, with no full APM or distributed tracing.
9. Vendor and subprocessor documentation is not mature enough for enterprise review.

Recommended Next Steps

0–30 days: Finalize the MediaHub dependency map, separate podcast success from playlist risk, **sign off Cognito Migration & MediaHub Auth Decommission spec** (CHT-owned IdP, MFA, MediaHub GoTrue shutdown for non-admins, API key integration), define the playlist decoupling plan, complete the subprocessor register, and assign owners/timelines in one leadership risk tracker.

30–90 days: **Migrate authentication to Amazon Cognito with TOTP MFA.** Coordinate **MediaHub GoTrue decommission for all non-admin users.** Expand CHT APIs for catalog/playlist data synced from MediaHub via API key. Move KOL profiles, therapy associations, playlist relationships, and content metadata into CHT-owned admin workflows. Preserve the direct YouTube API podcast model as the reference architecture.

60–120 days: Increase automated testing on high-risk workflows, especially authentication, payments, surveys, webhooks, registration, and admin flows. Add tests to PR validation. Enable RDS Multi-AZ, conduct a documented disaster recovery restore drill, and add application monitoring such as Sentry, Datadog, or an equivalent APM tool.

90–180 days: Engage a SOC 2 readiness auditor, complete compliance runbooks, finalize vendor and subprocessor documentation, complete the data retention policy, conduct a penetration test, and build an enterprise readiness packet for customer and partner conversations.

Bottom Line

CHT has a **strong production MVP**, but it is **not enterprise-ready yet**. Podcasts are working well and should be treated as the model. The remaining issue is that **auth users still live on MediaHub GoTrue**, conversation playlists, and KOL/content structure still create serious dependency risk.

The next step is **not more features**. The next step is **Cognito migration (CHT-owned IdP)**, MediaHub GoTrue decommission for end users, API-key-only MediaHub integration, testing, compliance evidence, observability, and infrastructure hardening.

Technical Review

Disclaimer

This document is an **internal engineering and compliance readiness assessment**. It is **not** a SOC 2 Type I or Type II audit report, not legal advice, and not a certification of HIPAA compliance. SOC 2 certification requires an independent CPA firm and formal control testing over a defined audit period.

1. Executive Summary

The CHT Platform (`cht-platform-tool`) is a production-deployed healthcare education and honorarium platform serving oncology HCPs, KOLs, and administrators. It integrates live sessions (Zoom), surveys (JotForm), honorarium payments (Bill.com), clinical content (MediaHub), podcasts (YouTube), and transactional email (Amazon SES) on AWS (ECS Fargate, RDS PostgreSQL, SQS, CloudFront).

Dimension	Verdict	Summary
Business use cases	Production-ready	Core flows (sessions, surveys, payments, catalog, admin) are implemented and deployed
Dependency posture	Moderate risk	Heavy reliance on 7+ third-party services; auth currently delegated to MediaHub GoTrue
SOC 2 readiness	Partial — Phase 1 controls in place	Strong infrastructure logging/encryption; policy gaps and no formal audit
Codebase quality	MVP+ / pre-enterprise	Solid architecture and CI foundations; low automated test coverage
Overall grade	MVP ready for controlled production	Suitable for live users with known gaps; not yet enterprise-grade without test coverage, MFA, DR hardening, and formal compliance program

Top 5 actions before enterprise / audit:

1. Complete compliance runbook ownership (named contacts, review dates)
 2. Increase automated test coverage and run tests on every PR
 3. Execute **Cognito migration** with required MFA (TOTP); coordinate MediaHub GoTrue decommission for non-admin users
 4. Enable RDS Multi-AZ in production; schedule DR restore drill
 5. Engage SOC 2 auditor for gap assessment against Trust Service Criteria
-

2. Platform Use Cases

2.1 Primary actors

Actor	Role	Primary surfaces
HCP / KOL	Healthcare professional learner or faculty	/app/* dashboard, live sessions, surveys, earnings, podcasts, chatbot
Admin	CHM operations staff	/admin/* scheduling, approvals, payments, HCP explorer, analytics
Public visitor	Unauthenticated user	Marketing home, public catalog, KOL network, live session listings
System integrators	Webhooks and workers	Zoom, JotForm, Bill.com callbacks; SQS consumers

2.2 Core use cases (implemented)

ID	Use case	Flow summary	Maturity
UC-01	Live session registration	HCP registers for webinar/office hours; admin approval optional	Production
UC-02	Session attendance tracking	Zoom webhooks record join/leave; linked to enrollment	Production
UC-03	Post-event survey	JotForm webhook → eligibility for honorarium	Production
UC-04	Honorarium payment	SQS → Python worker → Bill.com ACH/check	Production
UC-05	CME certificate delivery	Worker generates PDF (ReportLab) → SES email	Production (CME consumer partially stubbed)
UC-06	Admin program scheduling	Create Zoom meeting/webinar; clone JotForm survey template	Production
UC-07	Content catalog browsing	MediaHub API clips/playlists; disease-area filtering	Production
UC-08	Podcast catalog	YouTube-backed episode lists (Breast Friends, Cancer Unfiltered)	Production

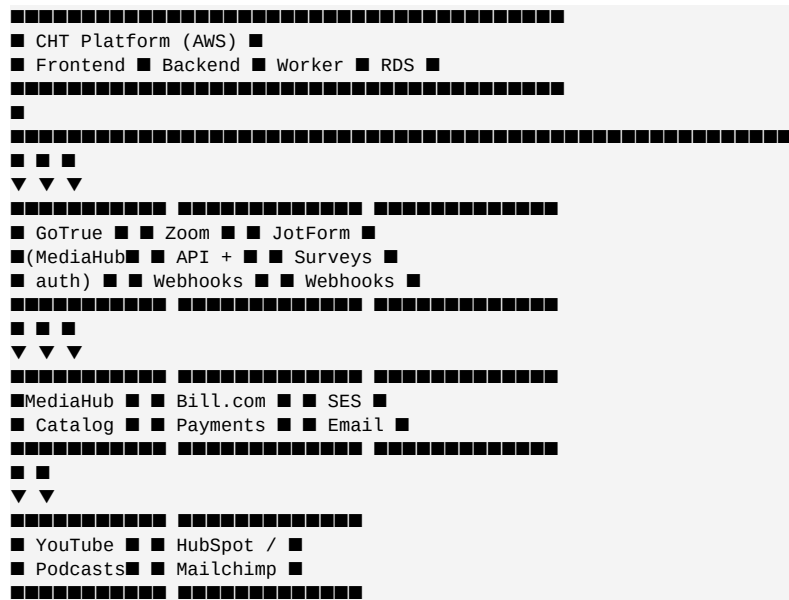
ID	Use case	Flow summary	Maturity
UC-09	KOL directory	Profile pages linked to catalog content	Production
UC-10	Admin payment queue	Review and trigger/retry honorarium payouts	Production
UC-11	HCP profile & settings	NPI, institution, payment eligibility (W-9 via Bill.com)	Production
UC-12	Chatbot access	Authenticated widget via GoTrue JWT token	Production
UC-13	Admin audit trail	Mutating admin API calls logged to AdminAuditLog	Production

2.3 Use case quality assessment

Criterion	Rating (1–5)	Notes
Functional completeness	4/5	End-to-end payment and session flows work; CME email consumer still has stub paths
Error recovery	3/5	SQS DLQs and payment idempotency exist; limited user-facing error boundaries on frontend
Observability per flow	3/5	CloudWatch alarms on DLQs and 5xx; no distributed tracing across Zoom → API → worker
Data consistency	4/5	Prisma transactions for payments; enrollment state machine is well-modeled
Security per use case	3/5	RBAC on admin routes; auth delegated to external GoTrue; MFA not yet implemented

3. Dependency Analysis

3.1 Dependency map



3.2 External dependency register

Service	Purpose	Auth method	Criticality	Single point of failure?	Planned change
GoTrue / Supabase (MediaHub)	User auth, OAuth, JWT	Shared JWT secret; CHT users = MH auth users	Critical	Yes — CHT does not own IdP	Migrate to Amazon Cognito (CHT-owned); MediaHub decommissions GoTrue for non-admins
Zoom	Live sessions, attendance	Server-to-Server OAuth + webhooks	Critical	Yes for live features	Monitor; vendor SLA
JotForm	Post-event surveys	API key + webhooks	High	Yes for payment eligibility	Template clone dependency
Bill.com	Honorarium payouts	Login + MFA-trusted session	Critical	Yes for payments	Remember-me rotation runbook
MediaHub	Video catalog, HCP sync	API key (server-to-server only)	High	Yes for catalog	Keep API key; no user auth; admin-only UI; CHT APIs to end users
Amazon SES	Transactional email	IAM (ECS task role)	High	No (AWS native)	—
YouTube Data API	Podcast episodes	API key	Medium	Degrades podcast UX only	—

Service	Purpose	Auth method	Criticality	Single point of failure?	Planned change
HubSpot / Mailchimp	Marketing sync on signup	API keys	Low	Fire-and-forget; signup not blocked	—
Chatbot (chmbot)	AI assistant widget	GoTrue JWT (today)	Medium	Degrades chatbot auth	Cognito JWT via CHT backend post-migration

3.3 Internal dependency quality

Layer	Technology	Coupling	Maintainability
Frontend → Backend	REST over HTTPS, cookie sessions	Low — API client abstraction	Good
Backend → Worker	SQS async messages	Low — queue contract	Good
Backend → RDS	Prisma ORM, 28 migrations	Medium — schema evolution managed	Good
Infra	Terraform modules (VPC, ECS, RDS, KMS, WAF)	Low — modular	Good
CI/CD	GitHub Actions + OIDC to AWS	Low — no long-lived keys	Good

3.4 Dependency risks and mitigations

Risk	Severity	Mitigation
End users auth on MediaHub GoTrue	Critical	Cognito migration; MediaHub decommissions GoTrue for non-admins
Auth owned by MediaHub GoTrue	High	CHT-owned Cognito pool per env, MFA required
Bill.com MFA session expiry (~35 min)	High	Cached pay login, remember-me ID rotation, documented runbook
Zoom webhook secret optional at startup	Medium	Make ZOOM_WEBHOOK_SECRET required in production validation
No cross-region DR deployed	Medium	Multi-AZ RDS; annual restore drill; optional us-east-2 stack
Subprocessor DPAs not centrally documented	Medium	Maintain vendor register with DPA/BAA status

4. SOC 2 Compliance Assessment

4.1 Certification status

The CHT Platform is **NOT SOC 2 certified**. This section evaluates readiness against common Trust Service Criteria (TSC) themes used in SOC 2 Type II audits: Security, Availability, Processing Integrity, Confidentiality, and Privacy.

4.2 Control maturity by TSC category

TSC category	Status	Evidence in codebase/infra	Gaps
Security (CC)	Partial	WAF, GuardDuty, CloudTrail, KMS encryption, RBAC, OIDC CI, Trivy scans, admin audit log	MFA not enforced; runbook contacts blank; no formal access review process documented
Availability (A)	Partial	Health checks, CloudWatch alarms, DLQ alerts, DR runbook, daily RDS backups	RDS single-AZ prod; no automated failover; RTO 4h is aspirational
Processing Integrity (PI)	Partial	Payment idempotency keys, Joi env validation, Prisma transactions	Limited automated tests on payment path; no formal reconciliation reports
Confidentiality (C)	Partial	RDS/S3/SQS KMS encryption, private subnets, Secrets Manager	PII not column-encrypted; secrets in local tfvars on dev machines
Privacy (P)	Partial	Public Privacy Policy (May 2026); Cognito migration plan for CHT-owned auth	No formal data retention schedule; subprocessors not in central register

4.3 Security controls inventory (implemented)

Control	Implementation	Location
Encryption at rest	KMS on RDS, S3, SQS, Secrets, CloudTrail, CloudWatch	infrastructure/terraform/modules/security/kms/
Encryption in transit	HTTPS (CloudFront, ALB), TLS to RDS in VPC	Terraform networking
Identity & access — app	JWT/session guards, @Roles(ADMIN), dev bypass blocked in prod	backend/src/auth/

Control	Implementation	Location
Identity & access — CI	GitHub OIDC, scoped IAM deny on access key creation	infrastructure/iam/
Audit logging — infra	CloudTrail multi-region, 365-day retention, log validation	modules/monitoring/cloudtrail/
Audit logging — app	AdminAuditLog for admin mutations	admin-audit.interceptor.ts
Network segmentation	Private subnets for ECS/RDS, WAF on CloudFront	VPC + WAF modules
Threat detection	GuardDuty → SNS alerts	modules/monitoring/guardduty/
Config compliance	AWS Config rules (CloudTrail, S3 public, encryption)	modules/monitoring/aws-config/
Vulnerability scanning	Trivy on PR (CRITICAL/HIGH fail)	.github/workflows/pr-validation.yml
Incident response	SEV 1–4 runbook, lockdown checklists	docs/compliance/incident-response.md
Disaster recovery	RPO/RTO targets, restore procedures	docs/compliance/disaster-recovery.md

4.4 SOC 2 readiness scorecard

Area	Score (0–100)	Interpretation
Technical controls	72	Above average for a Series A–stage product; infra is audit-friendly
Policies & procedures	45	Runbooks exist but incomplete (owners, dates, drills)
Evidence & monitoring	65	CloudTrail/Config/alerts good; no SIEM or formal log review cadence
Change management	70	PR validation, manual prod deploy with health gates
Vendor management	40	Integrations documented; no formal subprocessor register
Overall SOC 2 readiness	~58/100	Not audit-ready — estimated 3–6 months of policy + evidence work plus auditor engagement

4.5 Path to SOC 2 Type II (recommended)

- Month 1–2:** Assign control owners; complete IR/DR runbooks; subprocessor register; access review SOP

2. **Month 2–3:** Cognito + MFA; MediaHub GoTrue decommission for end users; rotate exposed secrets; enable Multi-AZ RDS
3. **Month 3–4:** Increase test coverage on payment/auth paths; DR restore drill with written evidence
4. **Month 4–6:** Select CPA firm; 3–6 month observation period; remediate auditor findings

5. Codebase Quality & Readiness Analysis

5.1 Architecture assessment

Aspect	Finding	Grade
Separation of concerns	NestJS modules per domain; Python workers for async	A
Data model	17 Prisma models, 57 indexes, 28 migrations	A-
API design	REST, global validation pipe, rate limiting, partial Swagger	B+
Frontend architecture	TanStack Query, centralized API client, lazy routes	B
Infrastructure as code	Modular Terraform, KMS, WAF, OIDC deploy	A-

5.2 Engineering quality metrics

Metric	Backend	Frontend	Worker
Source files	~138 TS	~173 TS/TSX	Python consumers
Test files	11 specs + 1 e2e	8 tests	4 test files
Approx. test surface coverage	~8% of modules	~5% of pages	Good for stubs
CI test gate on PR	No (lint/build only)	No	Trivy only
CI test gate on deploy	Yes	Yes	—

5.3 Strengths

- Production deployment on AWS with health checks, rollback workflow, and post-deploy diagnostics
- Payment idempotency and SQS dead-letter queues with alerting

- Structured logging (Pino JSON in production)
- Global rate limiting and input validation (class-validator + Joi startup validation)
- Admin audit trail for compliance evidence
- Privacy Policy and Terms published (May 2026)
- Compliance runbooks drafted (IR, DR)

5.4 Weaknesses (enterprise gaps)

Gap	Impact	Priority
Low automated test coverage	Regression risk on payment/auth flows	Critical
No frontend ErrorBoundary	Single component error crashes app	High
No APM (Sentry/Datadog)	Slow incident detection	High
Prometheus deps unused	No application metrics exported	Medium
Auth externalized to GoTrue	CHT users are MediaHub auth users; no MFA	High (Cognito migration + MH GoTrue decommission)
End users exposed to MediaHub OAuth	Breaks single-platform UX	High (resolved by Cognito on CHT domain)
RDS single-AZ production	Availability risk	High
Swagger exposed in all envs	Information disclosure	Low–Medium
CME/email worker stubs	Incomplete async feature paths	Medium

5.5 MVP vs enterprise readiness matrix

Capability	MVP threshold	Current state	Enterprise threshold	Gap
Core user flows	Working in prod	Met	Same + SLA	Minor
Authentication	Basic login/OAuth	Met	MFA, CHT-owned IdP, no MediaHub auth users	Cognito migration
Payment processing	Pays real users	Met	Reconciliation, audit trail, PCI-adjacent controls	Partial
Automated testing	Smoke tests	Partial	70%+ coverage, PR gates	Large
Monitoring	Logs + uptime	Partial	APM, tracing, SLOs	Medium

Capability	MVP threshold	Current state	Enterprise threshold	Gap
Security hardening	HTTPS + secrets	Met	WAF, GuardDuty, MFA, pen test	Partial
Compliance	Privacy policy	Partial	SOC 2 Type II, vendor register	Large
Disaster recovery	Backups exist	Partial	Multi-AZ, tested restore, RTO < 1h	Medium
Scalability	Single region ECS	Met for current load	Auto-scaling policies, load testing	Unknown

5.6 Overall readiness verdict

Level	Definition	CHT Platform today
Prototype	Local-only, no prod	■ Exceeded
MVP	Core flows in production, manual ops acceptable	■ Yes — production MVP
Growth	Test coverage, CHT-owned IdP (Cognito), monitoring, DR drills	■■ In progress (~60%)
Enterprise-grade	SOC 2, high availability, full observability, pen tested	■ Not yet (~40%)

Summary statement: The platform is **MVP-ready and operating in production** for its intended healthcare education and honorarium use cases. It is **not enterprise-grade** until Cognito migration (CHT-owned IdP + MFA), MediaHub GoTrue decommission for end users, test automation, Multi-AZ DR, formal compliance evidence, and application observability are completed.

6. Recommendations Roadmap

Immediate (0–30 days)

- Fill incident response and DR runbook owner names and review dates
- Add backend/frontend tests to PR validation workflow
- Require `ZOOM_WEBHOOK_SECRET` in production startup validation
- Document subprocessor register (Zoom, JotForm, Bill.com, MediaHub, GoTrue, SES, HubSpot)
- **Sign off Cognito Migration & MediaHub Auth Decommission spec**

Short-term (30–90 days)

- **Execute Cognito migration** with required TOTP MFA; **coordinate MediaHub GoTrue decommission for non-admin users**
- **Retain MediaHub API key** for server-to-server catalog and HCP sync only
- Enable RDS Multi-AZ for production
- Conduct and document DR restore drill
- Add React ErrorBoundary and Sentry (or equivalent) on frontend
- Target 40%+ test coverage on payments, auth, webhooks

Medium-term (90–180 days)

- Engage SOC 2 auditor for readiness assessment
 - Complete OpenAPI documentation for all controllers
 - Implement cross-region snapshot copies or hot standby
 - Formal access review quarterly for admin users and AWS console
 - Penetration test before enterprise customer contracts
-

7. Appendix

A. Key repository paths

Area	Path
Architecture	docs/engineering/architecture.md
Integrations	docs/engineering/integrations.md
Compliance index	docs/compliance/README.md
Incident response	docs/compliance/incident-response.md
Disaster recovery	docs/compliance/disaster-recovery.md
Privacy policy (UI)	frontend/src/pages/public/Privacy.tsx
Admin audit log	backend/src/modules/admin/admin-audit.interceptor.ts
CI validation	.github/workflows/pr-validation.yml
Production deploy	.github/workflows/deploy-prod.yml

B. Environment reference

Environment	URL	AWS stack
Production	testapp.communityhealth.media	us-east-1
Staging	staging.testapp.communityhealth.media	us-east-1-staging
Account	233636046512	Region us-east-1

C. Report methodology

This report was produced by static analysis of the `cht-platform-tool` repository: documentation review, infrastructure Terraform modules, CI workflows, test file inventory, auth and payment module inspection, and comparison against common SOC 2 Trust Service Criteria control themes. No penetration testing or dynamic production scanning was performed.

End of report — CHT Platform Combined Assessment, May 2026